

Module 22

Threat Intelligence & Adversary Emulation

Mengubah cyber threat intelligence menjadi eksperimen perilaku yang repeatable, observable, terukur, dan aman - lalu memakai hasilnya untuk memperbaiki detection dan defensive controls.

Learning path module ini

CTI intake -> source validation -> ATT&CK mapping -> adversary profile -> Navigator layer -> Attack Flow -> micro-emulation plan -> expected telemetry -> controlled execution -> detection result -> remediation -> retest.

Exit criteria

- Bisa membedakan raw indicator, context, TTP, procedure, dan analytical assessment; tidak menyamakan threat-intel feed dengan intelligence.
- Bisa memetakan behavior ke ATT&CK technique/sub-technique dengan evidence dan confidence, bukan berdasarkan nama tool saja.
- Bisa membuat Navigator layer dan Attack Flow yang menjelaskan prioritas dan sequence, bukan sekadar heatmap.
- Bisa menyusun micro-emulation plan lengkap dengan prerequisites, stop conditions, expected telemetry, cleanup, dan success criteria.
- Bisa menjalankan discovery-only emulation di VM/lab sendiri dan mengklasifikasikan hasil sebagai blocked, detected, logged-only, missed, atau not-testable.
- Bisa menulis hasil exercise yang actionable untuk Blue Team tanpa mengklaim coverage lebih luas dari evidence yang tersedia.

Authorized-lab rule Semua execution pada module ini hanya untuk host/VM/container milik sendiri atau platform yang secara eksplisit memberi authorization. Atomic tests wajib dibaca terlebih dahulu; jangan mengeksekusi prereq/payload yang belum dipahami.

1. Threat-Informed Defense: Bukan Sekadar ATT&CK Heatmap

Threat-informed defense (TID) berarti pengetahuan tentang adversary mengubah keputusan defense: apa yang dikumpulkan, apa yang diuji, apa yang dideteksi, dan apa yang diperbaiki. ATT&CK adalah knowledge base perilaku; ia bukan checklist compliance, bukan severity score, dan bukan bukti bahwa sebuah detection benar-benar bekerja.

Lapisan	Pertanyaan	Output
Cyber Threat Intelligence	Siapa/apa yang relevan bagi organisasi? Behavior apa yang benar-benar diamati?	source register, behavior observations, confidence
ATT&CK mapping	Behavior tersebut paling tepat dipetakan ke technique/sub-technique apa?	mapping dengan evidence + confidence
Emulation	Behavior mana yang aman dan bernilai untuk diuji? Dalam urutan apa?	scenario, steps, stop conditions
Telemetry & detection	Data apa yang seharusnya muncul? Analytic apa yang mengubah data menjadi signal?	telemetry matrix, hypotheses
Evaluation	Blocked? detected? logged-only? missed?	evidence-backed result
Improvement	Apa perubahan yang dibuat lalu diuji ulang?	control/detection change + retest
Prinsip Adversary emulation bukan kompetisi "seberapa jauh bisa compromise". Tujuannya meniru perilaku yang relevan secara cukup realistis untuk menguji defense, dengan scope dan blast radius yang terkontrol.		

Source: MITRE CTID - Threat-Informed Defense / INFORM; MITRE ATT&CK Adversary Emulation Plans.

IOC vs Behavior/TTP

Jenis	Contoh	Kelebihan	Keterbatasan
IOC	hash, domain, IP, filename	presisi tinggi untuk known artifact	mudah berubah; cepat stale
Procedure	"menjalankan whoami lalu systeminfo"	sangat konkret dan reproduceable	terikat implementasi tertentu
Technique/TTP	System Owner/User Discovery, System Information Discovery	lebih tahan perubahan tool	lebih ambigu; perlu context
Attack flow	sequence discovery -> credential access -> movement	menjelaskan hubungan antar-behavior	butuh intel yang cukup untuk sequence/conditions

2. CTI Lifecycle, Source Quality, dan Analytical Confidence

Sebelum mapping ke ATT&CK, analyst perlu membedakan fakta yang diamati dari interpretasi. Workflow praktis: Direction -> Collection -> Processing -> Analysis -> Dissemination -> Feedback. Di red-team context, hasil akhirnya bukan laporan panjang saja, tetapi daftar behavior yang punya provenance dan cukup kuat untuk dijadikan hypothesis/test.

Source quality checklist

Dimensi	Pertanyaan
Directness	Apakah sumber melihat aktivitas secara langsung, atau hanya mengutip sumber lain?
Recency	Apakah behavior masih relevan dengan platform/versi saat ini?

Corroboration	Apakah ada sumber independen yang mendukung observasi?
Specificity	Ada command/API/protocol/sequence konkret atau hanya label umum?
Scope	Apakah behavior diamati pada campaign/host tertentu atau digeneralisasi ke seluruh actor?
Bias & incentives	Apakah vendor/report punya framing atau data visibility yang terbatas?
Confidence != certainty Gunakan label low/medium/high sebagai komunikasi uncertainty. Jangan mengubah sebuah inference menjadi "fakta" hanya karena ATT&CK punya technique yang terdengar cocok.	

Lab 01 - Workspace & evidence layout

Buat workspace agar source, mappings, plan, telemetry, dan execution evidence tidak bercampur.

```
./labs/workspace-init.sh module22-threat-emulation
```

Deliverable: module22-threat-emulation/{01-intel,...,09-evidence}

Lab 02 - Source reliability scoring

Gunakan scoring helper hanya sebagai aid untuk memaksa lo mencatat provenance; analyst tetap memutuskan confidence.

```
python labs/source-score.py \
--source 'Synthetic incident note A' \
--type primary --recency current \
--directness direct --corroboration 2
```

Deliverable: JSON score + analyst notes

Lab note Score numerik bukan truth score dan bukan pengganti review.

3. MITRE ATT&CK v19.2: Data Model yang Harus Lo Pahami

Per Oktober 2026, current ATT&CK content adalah v19.2. ATT&CK v19 memecah tactic Defense Evasion menjadi Stealth dan Defense Impairment, sehingga materi lama yang masih menampilkan "Defense Evasion" sebagai satu tactic perlu dibaca dengan awareness terhadap versi. Selalu catat ATT&CK version pada deliverable yang sensitif terhadap perubahan taxonomy.

Object	Makna praktis	Contoh
Tactic	WHY - tujuan taktis adversary	Discovery
Technique	WHAT - behavior level yang relatif stabil	T1082 System Information Discovery
Sub-technique	variasi behavior yang lebih spesifik	T1087.001 Local Account
Procedure example	HOW - implementasi nyata pada actor/software/campaign	command/API/tool tertentu
Group / Campaign	WHO / operation context	observed actor/campaign objects
Software	Tool/malware yang dapat menjalankan berbagai behavior	bukan technique itu sendiri
Detection Strategy / Analytic	defensive logic dan data yang mendeteksi behavior	DET / AN objects

Tool name != technique Satu tool dapat melakukan banyak techniques; technique yang sama dapat dilakukan dengan puluhan tools. Mapping berdasarkan behavior dan outcome, bukan merek tool.

Current taxonomy note

Enterprise ATT&CK sekarang memiliki 15 tactics. Perubahan versi penting karena detection strategy, data components, procedure examples, dan tactic association bisa berubah. Pin atau catat versi saat membuat program jangka panjang.

Source: MITRE ATT&CK Version History; Updates April/August 2026; Enterprise Tactics.

4. CTI -> ATT&CK Mapping: Behavior First

Mapping yang bagus mulai dari kalimat behavior, bukan langsung mencari technique yang "terdengar mirip". Pecah observation menjadi actor/action/object/context/outcome, lalu cari technique yang definisinya paling dekat. Simpan evidence text asli dan confidence agar mapping bisa direview.

Langkah	Pertanyaan reviewer
1. Extract behavior	Apa tindakan yang benar-benar diamati?
2. Normalize wording	Apa action tanpa vendor/tool branding?
3. Candidate technique	Definisi ATT&CK mana yang paling sesuai?
4. Reject alternatives	Technique lain apa yang mirip dan kenapa ditolak?
5. Confidence	Direct evidence atau inference? Ada corroboration?
6. Version/provenance	ATT&CK version dan source mana yang dipakai?

Contoh mapping

Observation	Mapping	Kenapa
Operator menjalankan whoami untuk mengetahui identity saat ini	T1033	Tujuan langsung adalah mengetahui current user.

Operator mengumpulkan OS version, architecture, hostname	T1082	Behavior sesuai System Information Discovery.
Operator menampilkan proses berjalan	T1057	Object yang dicari adalah running processes.
Operator mencantumkan local accounts	T1087.001	Local account enumeration; bukan credential access.

Lab 03 - Validate ATT&CK mappings

Gunakan synthetic intel agar belajar mapping tanpa klaim atribusi terhadap actor nyata.

```
python labs/ttp-map.py \  
  labs/sample-intel.json \  
  --output module22-threat-emulation/02-mappings/mappings.csv
```

Deliverable: mappings.csv dengan sequence, technique ID, confidence, observation, source

Common mistake Jangan memetakan setiap command ke tactic Execution hanya karena command "dieksekusi". ATT&CK mapping mengikuti tujuan behavior yang dimodelkan, bukan fakta bahwa CPU menjalankan program.

5. Adversary Profile: Dari Brand Name ke Behavioral Model

Adversary profile untuk emulation harus memuat behavior yang relevan terhadap environment, bukan persona dramatis. Nama actor boleh menjadi pivot penelitian, tetapi test plan seharusnya dapat dijelaskan tanpa bergantung pada nama actor.

Field	Isi yang bernilai
Motivation / objective	espionage, extortion, access brokerage, disruption; hanya bila evidence mendukung
Victimology	industry, geography, technology footprint, identity/cloud/on-prem relevance
Access patterns	phishing, valid accounts, public-facing app, supply-chain - bila observed
Preferred platforms	Windows/Linux/cloud/SaaS/identity provider
Behavior set	technique/sub-technique + source + confidence
Sequence / conditions	behavior A biasanya mendahului B? ada decision point?
Constraints	unknowns, stale reporting, contradictory reports, limited visibility

Prioritization formula sederhana

Gunakan tiga sumbu: Threat relevance x Environmental exposure x Test safety/feasibility. Technique yang populer di ATT&CK tetapi tidak relevan dengan environment lo tidak otomatis menjadi prioritas.

Lab 04 - Build the synthetic adversary profile

Review labs/sample-intel.json. Tambahkan context organisasi fiktif: Windows endpoints, local admin restricted, EDR enabled, no internet egress from lab.

Deliverable: 01-intel/adversary-profile.md

6. Adversary Emulation Plan: Scenario, Bukan Checklist Technique

MITRE/CTID membedakan full emulation plan dan micro emulation plan. Full plan mencoba rantai behavior yang lebih luas; micro plan memusatkan test pada behavior compound yang lebih kecil agar mudah diulang. Untuk belajar, kita pakai micro-emulation: 3-5 behavior, satu objective, satu host/VM, telemetry jelas, dan cleanup sederhana.

Elemen plan	Isi minimum
Objective	pertanyaan defense yang ingin dijawab
Scope	host, identity, network, time window, allowed actions
Assumptions	EDR/logging aktif? account tersedia? snapshot?
Behavior steps	ATT&CK ID + rationale + concrete safe action
Prerequisites	tools/config/data collection yang harus siap
Expected telemetry	log/data component/event/process yang diharapkan
Stop conditions	health issue, unexpected privilege, scope ambiguity, missing telemetry
Cleanup	artifact/config/process/session yang harus dihapus/ditutup
Success criteria	blocked/detected/logged/missed dan evidence yang diperlukan

Lab 05 - Generate a micro-emulation plan

Ubah mapping yang sudah direview menjadi plan awal, lalu edit manual supaya sesuai environment.

```
python labs/emulation-plan.py \  
  module22-threat-emulation/02-mappings/mappings.csv \  
  --output module22-threat-emulation/05-plan/micro-plan.md
```

Deliverable: 05-plan/micro-plan.md yang sudah direview

Pentest vs adversary emulation Pentest mencari kelemahan/impact dalam scope. Adversary emulation menguji defense terhadap behavior tertentu. Keduanya bisa overlap, tetapi objective dan success criteria berbeda.

Source: MITRE ATT&CK Adversary Emulation Plans; CTID Adversary Emulation Library & Micro Emulation Plans.

7. ATT&CK Navigator: Visualisasi Prioritas, Bukan Bukti Coverage

Navigator menyimpan layer sebagai JSON dan memungkinkan color, score, comment, metadata, filter platform, dan kombinasi layer. Gunakan layer untuk komunikasi: mapping confidence, emulation scope, detection results, atau backlog. Selalu tulis arti score/color di legend.

Layer use-case	Score/color harus berarti
Threat layer	relevance/frequency/confidence dari intel
Emulation layer	planned / executed / deferred
Detection layer	evidence-backed result, bukan "rule exists"
Gap layer	missing telemetry / missed detection / not testable

Lab 06 - Generate Navigator layer

Helper memberi score berdasarkan mapping confidence. Ini sengaja BUKAN detection score.

```
python labs/navigator-layer.py \
  module22-threat-emulation/02-mappings/mappings.csv \
  --output module22-threat-emulation/03-navigator/threat-layer.json
```

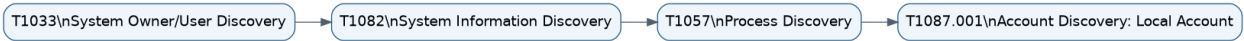
Deliverable: 03-navigator/threat-layer.json

Sensitive layers Navigator hosted resmi berjalan client-side dan tidak menyimpan uploaded layers server-side, tetapi MITRE tetap menyarankan local instance bila layer mengandung data sensitif. Untuk latihan ini gunakan synthetic data saja.

Source: MITRE ATT&CK Navigator Usage + Layer Format v4.5.

8. Attack Flow: Dari Daftar TTP Menjadi Sequence

Heatmap menjawab "behavior apa?" tetapi tidak selalu menjawab "bagaimana behavior itu tersusun?". Attack Flow memodelkan actions, conditions, dan relationships sehingga sequence, branch, dependency, dan failure path dapat dikomunikasikan.



Synthetic discovery flow - sequence untuk training, bukan klaim tentang actor nyata.

Flow thinking questions

- Behavior mana yang menjadi prerequisite untuk behavior berikutnya?
- Apa condition yang membuat adversary memilih branch A vs B?
- Apa expected failure path jika credential/route/privilege tidak tersedia?
- Choke point mana yang paling bernilai untuk prevent/detect?
- Jika satu technique hilang dari telemetry, apakah sequence masih dapat direkonstruksi?

Lab 07 - Generate flow graph

Bangun flow dari mapping CSV; Graphviz menghasilkan SVG yang dapat dimasukkan ke report.

```
python labs/attack-flow.py \
  module22-threat-emulation/02-mappings/mappings.csv \
  --dot module22-threat-emulation/04-flow/discovery.dot \
  --svg module22-threat-emulation/04-flow/discovery.svg
```

Deliverable: 04-flow/discovery.dot + discovery.svg

Source: MITRE CTID Attack Flow (latest project release July 2026).

9. Telemetry & Detection Hypothesis: Behavior Harus Observable

Sebelum execution, tulis expected telemetry. Kalau collection tidak ada, kegagalan detection bisa sebenarnya adalah visibility gap. ATT&CK v18+ memperkenalkan Detection Strategies dan Analytics sebagai model defensive yang lebih eksplisit. Contoh current T1057 detection strategy mengaitkan process discovery dengan process creation/API context dan parent/remote-origin context.

Kolom telemetry matrix	Contoh
Technique	T1057 Process Discovery
Action	Get-Process / tasklist / ps
Data source / component	process creation; process API access bila tersedia
Expected evidence	process name, command line, user, parent, timestamp, host
Context	interactive admin? script? remote session? unusual parent?
Detection question	apakah behavior + context cukup membedakan admin normal dari adversary discovery?
Result	blocked / detected / logged-only / missed / not-testable

Lab 08 - Build telemetry matrix

Generate baseline matrix lalu isi collection status sesuai lab lo.

```
python labs/telemetry-matrix.py \
  module22-threat-emulation/02-mappings/mappings.csv \
  --output module22-threat-emulation/06-telemetry/telemetry.csv
```

Deliverable: 06-telemetry/telemetry.csv

Ambiguous behavior whoami, systeminfo, Get-Process, dan account enumeration juga dilakukan admin legitimate. Detection yang matang memakai context: ancestry, session source, user role, sequence, timing, dan follow-on behavior.

Source: MITRE ATT&CK T1082, T1057, T1033, T1087.001; Detection Strategy objects.

10. Controlled Behavior Simulation - Linux / Omarchy

Sebelum memakai emulation framework, jalankan behavior read-only secara manual agar lo paham observability. Script di package hanya melakukan local discovery dan menyimpan output; tidak mengubah config, tidak menambah persistence, dan tidak mengakses credential secret.

Lab 09 - Run safe discovery chain on Omarchy

Jalankan hanya pada device/lab milik sendiri. Cocok untuk mempelajari evidence harness, bukan untuk menguji stealth.

```
./labs/discovery-sim.sh module22-threat-emulation/07-execution
```

Deliverable: activity.jsonl + satu output file per technique

Command equivalence

ATT&CK	Linux/Omarchy behavior	Windows equivalent
T1033	whoami	whoami
T1082	uname -a; /etc/os-release	systeminfo / Get-ComputerInfo
T1057	ps -eo ...	tasklist / Get-Process
T1087.001	getent passwd	Get-LocalUser
Blue Team perspective Kalau lab tidak punya audit/EDR telemetry, jangan menulis "detection missed". Status yang benar bisa "not-testable" atau "telemetry unavailable".		

11. Controlled Behavior Simulation - Windows VM

Windows VM dari module sebelumnya cocok untuk experiment karena discovery commands punya padanan telemetry yang umum di EDR/Sysmon/Windows auditing. Script helper tetap read-only dan output disimpan ke Documents\RedTeam\Module22\execution.

Lab 10 - Run Windows discovery simulation

Jalankan di disposable Windows VM, bukan workstation produksi.

```
powershell -ExecutionPolicy Bypass -File .\windows-discovery-sim.ps1
```

Deliverable: activity.json + T1033/T1082/T1057/T1087_001 outputs

Telemetry review checklist

- Timestamp cocok antara harness dan log?
- Process name dan command line terlihat?
- User/session context terlihat?
- Parent process membantu membedakan interactive admin vs script?
- Ada alert, hanya raw log, atau tidak ada visibility sama sekali?
- Detection membutuhkan sequence/correlation atau satu event sudah cukup?

12. Atomic Red Team: Dari Manual Behavior ke Repeatable Test

Atomic Red Team adalah library test kecil yang dipetakan ke ATT&CK. Test definitions memuat attack commands, inputs, dependencies, dan bila tersedia cleanup. Keuntungan utama adalah repeatability; risikonya adalah menganggap semua atomics aman hanya karena open-source. Review source dan prerequisites tetap wajib.

Sebelum execute atomic	Kenapa
Confirm authorization + test machine	Atomic docs eksplisit mensyaratkan permission dan test host.
Show details	Baca exact command, executor, inputs, dependencies.
Inspect files/URLs	Prerequisite dapat mengunduh/menjalankan dependency.
Understand cleanup	Tidak semua test sepenuhnya reversible.
Snapshot / backup	Membatasi blast radius bila test tidak berjalan sesuai ekspektasi.
Verify telemetry	Tujuan test adalah belajar hasil prevention/detection, bukan sekadar command success.

Optional Windows VM setup

```
Install-Module -Name invoke-atomicredteam,powershell-yaml -Scope CurrentUser

# Setelah atomics tersedia pada test VM:
Invoke-AtomicTest T1082 -ShowDetailsBrief
Invoke-AtomicTest T1082 -ShowDetails
```

Jangan copy-paste installer blind Dokumentasi resmi menyediakan installer one-liner, tetapi untuk learning/production-minded workflow lebih baik

review script/repository, pin commit/release bila memungkinkan, dan pahami perubahan sebelum menjalankan.

Lab 11 - Atomic review-only

Pilih satu T1082 atau T1057 test yang cocok platform. Jangan execute dulu; tulis executor, exact command, dependencies, expected artifacts, cleanup, dan telemetry.

Deliverable: 05-plan/atomic-review.md

Lab 12 - Optional low-risk atomic execution

Setelah review dan snapshot, jalankan hanya test discovery yang command-nya setara native system information/process discovery. Gunakan nomor/GUID yang lo review dari -ShowDetails; jangan mengasumsikan test index stabil.

```
Invoke-AtomicTest T1082 -ShowDetailsBrief
# pilih test yang sudah direview
Invoke-AtomicTest T1082 -TestNumbers <reviewed-number>
Invoke-AtomicTest T1082 -Cleanup
```

Deliverable: 07-execution/atomic-notes.md

Lab note Kalau prerequisites mengunduh payload/tool yang tidak lo pahami, skip dan gunakan manual simulation.

Source: Atomic Red Team Getting Started; Invoke-AtomicRedTeam docs.

13. Measuring Outcomes Tanpa Vanity Metrics

"Technique berwarna hijau" tidak cukup. Satu detection mungkin hanya menangkap satu implementation dari banyak cara melakukan technique. Ukur experiment secara evidence-backed dan jangan generalisasi lebih jauh dari behavior yang diuji.

Status	Makna
blocked	control mencegah behavior mencapai intended effect
detected	telemetry + analytic menghasilkan signal/alert yang dapat ditindak
logged-only	raw telemetry ada tetapi tidak menghasilkan detection
missed	collection tersedia dan behavior terjadi, tetapi detection yang diharapkan tidak muncul
not-testable	scope/telemetry/prerequisite tidak memungkinkan kesimpulan yang valid

Dimensions worth tracking

Dimension	Pertanyaan
Visibility	Apakah required telemetry ada dan lengkap?
Detection fidelity	Signal benar-benar terkait behavior yang diuji?
Context quality	User/parent/session/host/sequence cukup untuk triage?
Timeliness	Berapa delay dari behavior ke evidence/alert?
Actionability	Analyst tahu next step dari alert?
Repeatability	Hasil konsisten saat test diulang?
Cleanup	Tidak ada artifact/config residual?

Lab 13 - Record results

Catat satu result per technique dengan telemetry reference yang spesifik.

```
python labs/result-score.py \
--technique T1082 \
--status logged-only \
--telemetry 'EDR event / screenshot / query ID' \
--notes 'Observed process telemetry; no analytic fired.' \
--output module22-threat-emulation/08-results/results.csv
```

Deliverable: 08-results/results.csv

14. Improve -> Retest -> Compare

Exercise belum selesai saat gap ditemukan. Siklus threat-informed testing harus menghasilkan perubahan lalu retest dengan behavior yang sama. Pertahankan input, host build, identity, dan collection sebisa mungkin agar before/after comparison valid.

Before	Change	Retest evidence
logged-only T1057	analytic menambahkan parent/session context	alert muncul + raw event tetap sama
not-testable T1082	enable required process telemetry	test sekarang menghasilkan log
noisy T1033 detection	add sequence/context constraints	fewer benign hits tanpa kehilangan test signal

Lab 14 - Retest after one defensive change

Pilih satu result, ubah satu control/analytic di lab, jalankan behavior yang sama, lalu bandingkan evidence.

Deliverable: 08-results/retest-notes.md

Lab 15 - Freeze evidence integrity

Hash seluruh workspace setelah exercise agar perubahan evidence berikutnya terlihat.

```
./labs/evidence-manifest.sh module22-threat-emulation
```

Deliverable: 09-evidence/sha256-manifest.txt

15. Capstone - Threat Report to Emulation Exercise

Scenario: organisasi fiktif menggunakan Windows endpoints + EDR dan ingin memastikan discovery behavior dasar dapat terlihat. Lo menerima synthetic report di labs/sample-intel.json. Tugas lo adalah mengubahnya menjadi exercise lengkap tanpa menambah behavior yang tidak didukung evidence.

Phase	Deliverable	Pass condition
1. Intel intake	source register + confidence	fact vs inference jelas
2. ATT&CK map	mappings.csv	setiap mapping punya evidence + confidence
3. Threat view	Navigator layer	legend menjelaskan arti score/color
4. Sequence	Attack Flow SVG/DOT	urutan dan dependency jelas
5. Plan	micro-plan.md	scope, stop, telemetry, cleanup ada
6. Execute	4 discovery behaviors	lab only; evidence timestamped
7. Evaluate	results.csv	status tidak overclaim
8. Improve/retest	before-after note	satu perubahan diuji ulang
9. Evidence	SHA-256 manifest	manifest verifies

Capstone rule Tidak ada credential dumping, persistence, defense evasion, remote execution, C2, atau destructive behavior. Fokusnya threat-intel-to-test methodology dan detection validation.

16. Troubleshooting & Common Failure Modes

Masalah	Kemungkinan akar masalah	Perbaikan
Mapping terasa "semua cocok"	behavior terlalu abstrak	kembali ke exact observation; cari object/action/outcome
Navigator penuh warna tapi tidak actionable	score tidak punya definisi	buat legend + provenance + layer purpose
Atomic gagal prereq	dependency/environment mismatch	review GetPrereqs; jangan force-install blind
Tidak ada alert	collection belum aktif atau analytic tidak cover implementation	cek raw telemetry dulu sebelum menyimpulkan missed
Hasil berubah tiap run	environment/input berbeda	pin host snapshot, identity, action, timing sebisa mungkin
Cleanup tidak yakin	test terlalu kompleks	turunkan scope ke manual/native discovery behavior

17. Knowledge Check

1. Kenapa IOC feed belum otomatis menjadi cyber threat intelligence?
2. Apa beda tactic, technique, sub-technique, dan procedure example?
3. Kenapa tool name tidak boleh langsung dijadikan technique mapping?
4. Kenapa ATT&CK version harus dicatat pada long-lived deliverable?
5. Apa perubahan besar Enterprise tactics pada ATT&CK v19?
6. Kenapa confidence mapping perlu disimpan bersama evidence?
7. Kapan micro-emulation lebih cocok daripada full emulation?
8. Kenapa Navigator heatmap bukan bukti detection coverage?
9. Apa masalah yang diselesaikan Attack Flow dibanding daftar techniques?
10. Apa beda telemetry gap dengan detection miss?
11. Kenapa discovery command seperti whoami tetap ambiguous dari sisi detection?
12. Apa yang wajib direview sebelum menjalankan Atomic Red Team test?
13. Apa beda status logged-only dan missed?
14. Kenapa retest harus menjaga input/environment sebisa mungkin?
15. Apa deliverable minimum agar emulation result dapat direview oleh Blue Team lain?

18. Cheat Sheet

Task	Command / artifact
Init workspace	./labs/workspace-init.sh module22-threat-emulation
Validate mapping	python labs/ttp-map.py labs/sample-intel.json --output ../mappings.csv
Navigator	python labs/navigator-layer.py mappings.csv --output threat-layer.json
Attack Flow	python labs/attack-flow.py mappings.csv --dot flow.dot --svg flow.svg
Plan	python labs/emulation-plan.py mappings.csv --output micro-plan.md
Telemetry	python labs/telemetry-matrix.py mappings.csv --output telemetry.csv

Linux sim	./labs/discovery-sim.sh .../07-execution
Windows sim	powershell -File .\windows-discovery-sim.ps1
Atomic inspect	Invoke-AtomicTest T1082 -ShowDetails
Result	python labs/result-score.py --technique ... --status ...
Evidence hash	./labs/evidence-manifest.sh module22-threat-emulation

19. Appendix A - CTI Source Register Template

Gunakan source register untuk menjaga provenance. Satu report bisa punya banyak observation; satu observation bisa didukung beberapa source. Jangan hanya menyimpan URL tanpa publication date dan caveat.

Field	Isi yang dicatat
Source ID	unik, mis. SRC-001
Title / publisher	judul asli + organisasi/publisher
Published / accessed	tanggal publikasi dan tanggal lo mengakses
Source type	primary / official / secondary / community
Directness	direct observation / corroborated inference / inference
Behavior excerpt	paraphrase singkat dari behavior yang relevan
Corroboration	source lain yang mendukung atau bertentangan
Confidence	low / medium / high + rationale
Caveat	visibility limit, stale data, attribution uncertainty
Pisahkan tiga confidence Attribution confidence (siapa pelakunya), mapping confidence (ATT&CK ID mana yang cocok), dan emulation confidence (seberapa mirip test kita dengan behavior asli) adalah tiga hal berbeda. Jangan digabung menjadi satu angka.	

20. Appendix B - ATT&CK Mapping Review Worksheet

Review item	Pertanyaan wajib
Exact observation	Apa yang benar-benar terjadi menurut source?
Normalized behavior	Bagaimana behavior dijelaskan tanpa nama malware/tool?
Candidate ID	Technique/sub-technique ATT&CK apa?
Definition fit	Kata/konsep mana pada definisi ATT&CK yang cocok?
Alternatives	ID lain apa yang dipertimbangkan?
Reject rationale	Kenapa alternative tersebut kurang tepat?
Procedure support	Ada procedure example yang serupa? hanya sebagai support, bukan bukti otomatis.
Source + confidence	Provenance dan uncertainty jelas?
Version	ATT&CK version yang digunakan?

Quality gate mapping

- Reviewer lain bisa mengerti mapping tanpa membuka tool yang dipakai adversary.
- Mapping tidak mengklaim objective/impact yang tidak ada pada source.
- Sub-technique dipilih hanya jika detail source cukup spesifik.
- Jika source hanya berkata "enumerated system", mapping tidak dipaksa menjadi beberapa techniques sekaligus.
- Ambiguity dicatat, bukan disembunyikan.

21. Appendix C - Reusable Emulation Step Card

Setiap action pada plan sebaiknya punya step card. Ini membuat operator, Blue Team, dan reviewer memiliki definisi test yang sama.

Field	Contoh / isi
Step ID	EMU-03
ATT&CK behavior	T1057 Process Discovery
Intel rationale	source/observation yang membuat behavior relevan
Exact implementation	command/API yang sudah direview
Host / identity	LAB-WIN11 / standard user
Prerequisites	snapshot, EDR online, logging verified
Expected effect	process list ditampilkan; tidak ada persistent change
Expected telemetry	process creation, command line, user, parent, timestamp
Stop condition	host instability, privilege surprise, missing scope, unexpected download
Cleanup	none / exact cleanup command
Evidence	screenshot/query/event ID/file hash
Result	blocked/detected/logged-only/missed/not-testable

22. Appendix D - Blue Team Observation Card

Field	Pertanyaan
Exercise timestamp	kapan step dimulai dan selesai?
Telemetry source	EDR, Sysmon, Security log, auditd, SIEM, custom harness?
Raw evidence	event/query/document mana yang membuktikan visibility?
Analytic / rule	rule name/version/query apa yang seharusnya detect?
Signal timing	berapa lama dari behavior ke log/alert?
Context quality	user, parent, session, host, command line, sequence tersedia?
Benign analog	admin/tooling legitimate apa yang mirip?
Decision	true positive, expected benign, inconclusive?
Action	tune, add telemetry, document limitation, no change
Detection result yang sehat Satu test bisa menghasilkan "logged-only" dan tetap berguna: itu membuktikan sensor melihat behavior, tetapi analytic belum mengubahnya menjadi actionable signal.	

23. Appendix E - After Action Review & Retest Plan

AAR section	Isi
Objective answered?	ya/tidak/parsial + evidence
What worked	prevention/detection/telemetry yang berhasil
What failed	miss, telemetry gap, broken assumption, test design issue
Unexpected findings	behavior/log/operational side effect yang tidak diprediksi
Changes	rule/config/logging/process yang akan diubah
Owner	siapa bertanggung jawab
Retest condition	kapan dan dengan step/input apa
Residual risk	apa yang tetap tidak teruji atau tidak terlihat

Exit checklist module

- Source register punya provenance dan caveat.
- ATT&CK mappings punya evidence, rejected alternatives, dan confidence.
- Navigator layer punya legend yang menjelaskan arti score/color.
- Attack Flow menggambarkan sequence/dependency, bukan hanya empat box acak.
- Setiap emulation step punya expected telemetry dan stop condition.
- Execution hanya pada lab/VM authorized dan cleanup diverifikasi.
- Result menggunakan status yang tepat; tidak menyebut missed saat telemetry tidak tersedia.
- Satu gap diperbaiki lalu diuji ulang dengan evidence before/after.
- Evidence manifest dibuat setelah exercise selesai.

References & Version Notes

MITRE ATT&CK Version History - current v19.2 (Aug 2026): <https://attack.mitre.org/resources/versions/>

MITRE ATT&CK v19 update - Stealth / Defense Impairment split: <https://attack.mitre.org/resources/updates/updates-april-2026/>

MITRE ATT&CK Enterprise Tactics: <https://attack.mitre.org/tactics/>

MITRE ATT&CK Adversary Emulation Plans: <https://attack.mitre.org/resources/adversary-emulation-plans/>

MITRE ATT&CK Navigator: <https://github.com/mitre-attack/attack-navigator>

Navigator Layer Format v4.5: <https://github.com/mitre-attack/attack-navigator/blob/master/layers/spec/v4.5/layerformat.md>

MITRE CTID Adversary Emulation Library: <https://ctid.mitre.org/resources/adversary-emulation-library/>

MITRE CTID Micro Emulation Plans: <https://ctid.mitre.org/projects/micro-emulation-plans/>

MITRE CTID Attack Flow - July 2026 release: <https://ctid.mitre.org/projects/attack-flow>

Atomic Red Team Getting Started: <https://www.atomicredteam.io/docs/atomic-red-team>

Invoke-AtomicRedTeam: <https://www.atomicredteam.io/docs/invoke-atomicredteam>

ATT&CK T1082 System Information Discovery: <https://attack.mitre.org/techniques/T1082/>

ATT&CK T1057 Process Discovery: <https://attack.mitre.org/techniques/T1057/>

ATT&CK T1033 System Owner/User Discovery: <https://attack.mitre.org/techniques/T1033/>

ATT&CK T1087.001 Local Account Discovery: <https://attack.mitre.org/techniques/T1087/001/>

Build note: module content uses ATT&CK terminology current to v19.2 as of 2026-10. Synthetic examples are intentionally non-attributed and discovery-only.